ShieldAI

AI-Powered Phishing Detection: From Rule-Based Models to Intelligent Agents

Eric Ortega Rodriguez | CYBERSEC 520 | Duke University | Spring 2026

Phishing Is the #1 Cyber Threat Facing Organizations Today

$4.88M
Average cost per phishing breach (IBM, 2025)

90%+
Of cyberattacks begin with phishing (CISA, 2025)

254 days
Average time to detect and contain a breach (IBM, 2025)

14x
Surge in AI-generated phishing campaigns (Hoxhunt, 2026)

AI is making the problem worse

AI-crafted phishing emails now achieve click rates up to 54% compared to 12% for traditionally written emails. Breaches identified after 200 days cost $1.2M more than those caught early. The cost of inaction compounds every day.

Sources: IBM Cost of a Data Breach 2025 · CISA · Hoxhunt Phishing Trends 2026 · Keepnet Labs 2026

Traditional Defenses Are Losing the Arms Race

Why Rule-Based Systems Fail

- ✕ Match on surface patterns like keywords and domains learned from old training data
- ✕ Cannot understand semantic intent or contextual meaning
- ✕ Require constant manual retraining as attack patterns evolve
- ✕ Brittle: a single word swap can bypass the entire detection logic
- ✕ Generate high false positive rates that overwhelm security teams

AI Is Already Reshaping Cybersecurity

In April 2026, Anthropic launched Project Glasswing: a coalition of 40+ organizations including Amazon, Apple, Google, and Microsoft, using an unreleased AI model to discover zero-day vulnerabilities at a scale no human team could match.

Mythos Preview identified thousands of critical bugs in every major OS and browser, including a 27-year-old flaw in OpenBSD.

The message for defenders is clear: AI is not a future investment. It is a present necessity.

Source: Anthropic / CyberScoop, April 2026

ShieldAI: Two Approaches, Head to Head

Traditional ML

Random Forest + XGBoost

- TF-IDF vectorization on email text
- 11 handcrafted signal features
- Trained on 39,154 CEAS_08 emails
- Instant scoring, no API call needed
- Interpretable feature importance

VS

LLM Agent

GPT 4.1 Mini via Duke LiteLLM

- 4 specialized investigative tools
- Reasons about email intent semantically
- No retraining needed as attacks evolve
- Produces human-readable verdict
- Executive summary for non-technical staff

Random Forest and XGBoost specifically because both are well-suited to tabular feature classification, handle class imbalance , and widely deployed in production security tooling.

Two Datasets: Training and a Real-World Stress Test

PRIMARY DATASET

CEAS_08

39,154 labeled emails

56% phishing **44%** legitimate

2008 era 80/20 train-test split

Training academic benchmark dataset

SECONDARY DATASET (GENERALIZABILITY TEST)

SpamAssassin

5,796 emails (never used in training)

33% phishing **67%** legitimate

Different era distinct vocabulary and style

Compatibility headers parsed via regex

SpamAssassin was never shown to the models during training. It serves as a true out-of-distribution generalizability test.

Making SpamAssassin Compatible with CEAS_08

The Challenge: SpamAssassin stores each email as a single raw text blob with headers and body inline. CEAS_08 has pre-parsed columns. To test generalizability, the schemas had to match exactly.

1 Extract Fields via Regex

Four custom functions parse each raw email string to pull out sender address, subject line, body text, and URL presence.

```
extract_sender()
extract_subject()
extract_body()
url detection
```

2 Align to CEAS_08 Schema

Placeholder columns added for receiver and date. Binary URL flag (0/1) matches CEAS_08 exactly. Combined text field created from subject + body.

```
sender, subject, body
urls (binary 0/1)
receiver, date = ''
```

3 Verify Extraction Quality

Spot-checked extraction rates to confirm schema alignment before running any model inference on the secondary dataset.

```
5,784/5,796 senders (99.8%)
5,790/5,796 subjects (99.9%)
5,733/5,796 bodies >50 chars
```

Two Datasets: Training and a Real-World Stress Test

PRIMARY DATASET

CEAS_08

Sender: Young@iworld.de
Subject: "Never agree to be a loser"
Body: "Buck up, your troubles caused by small dimension will soon be over!"

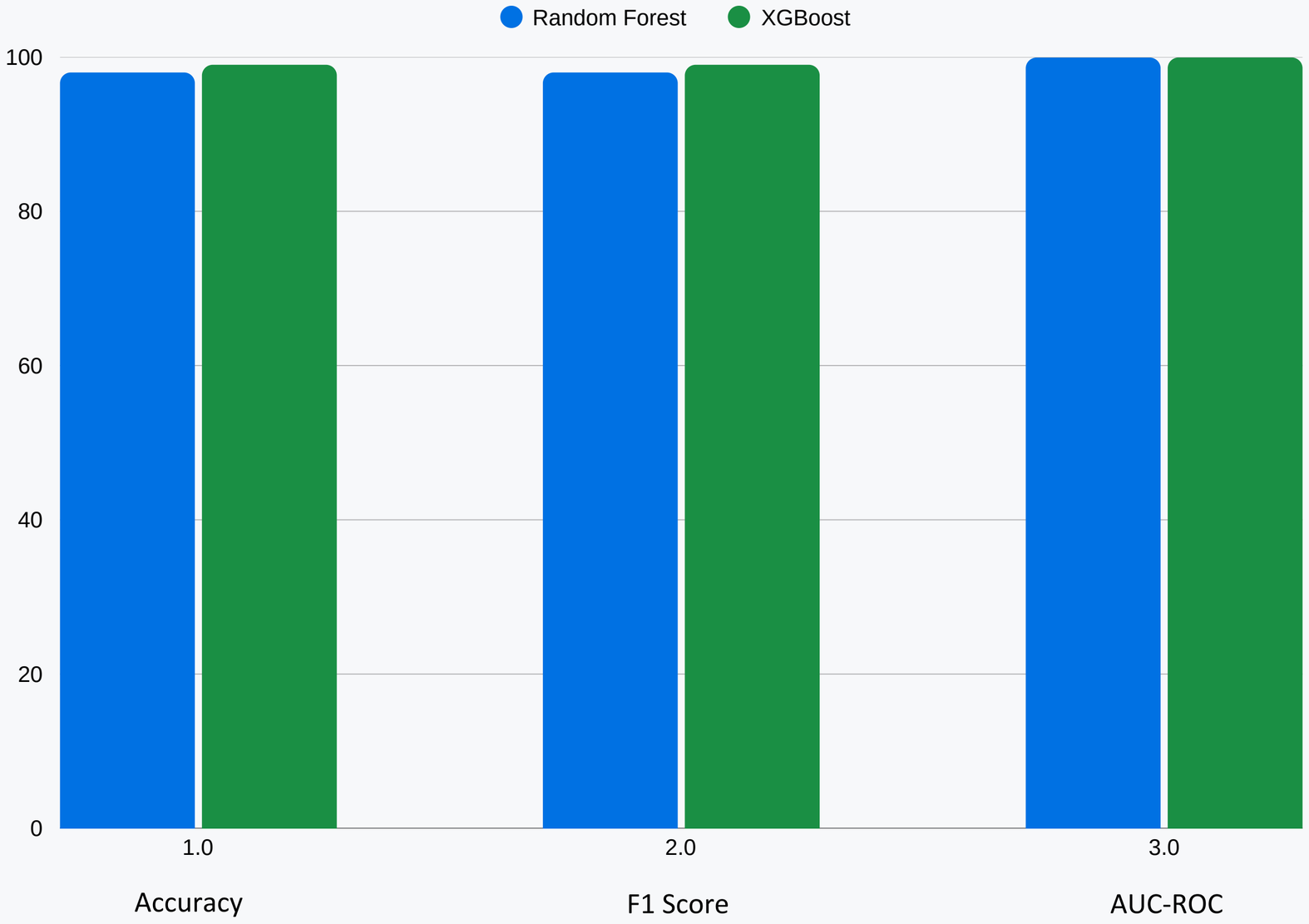
SECONDARY DATASET (GENERALIZABILITY TEST)

SpamAssassin

Sender: gort44@excite.com
Subject: "Cash in on your home equity"
Body: "Mortgage rates haven't been this low in years, take action now! Refinance your home..."

SpamAssassin was never shown to the models during training. It serves as a true out-of-distribution generalizability test.

Both Models Perform Near-Perfectly on the Primary Dataset



Random Forest

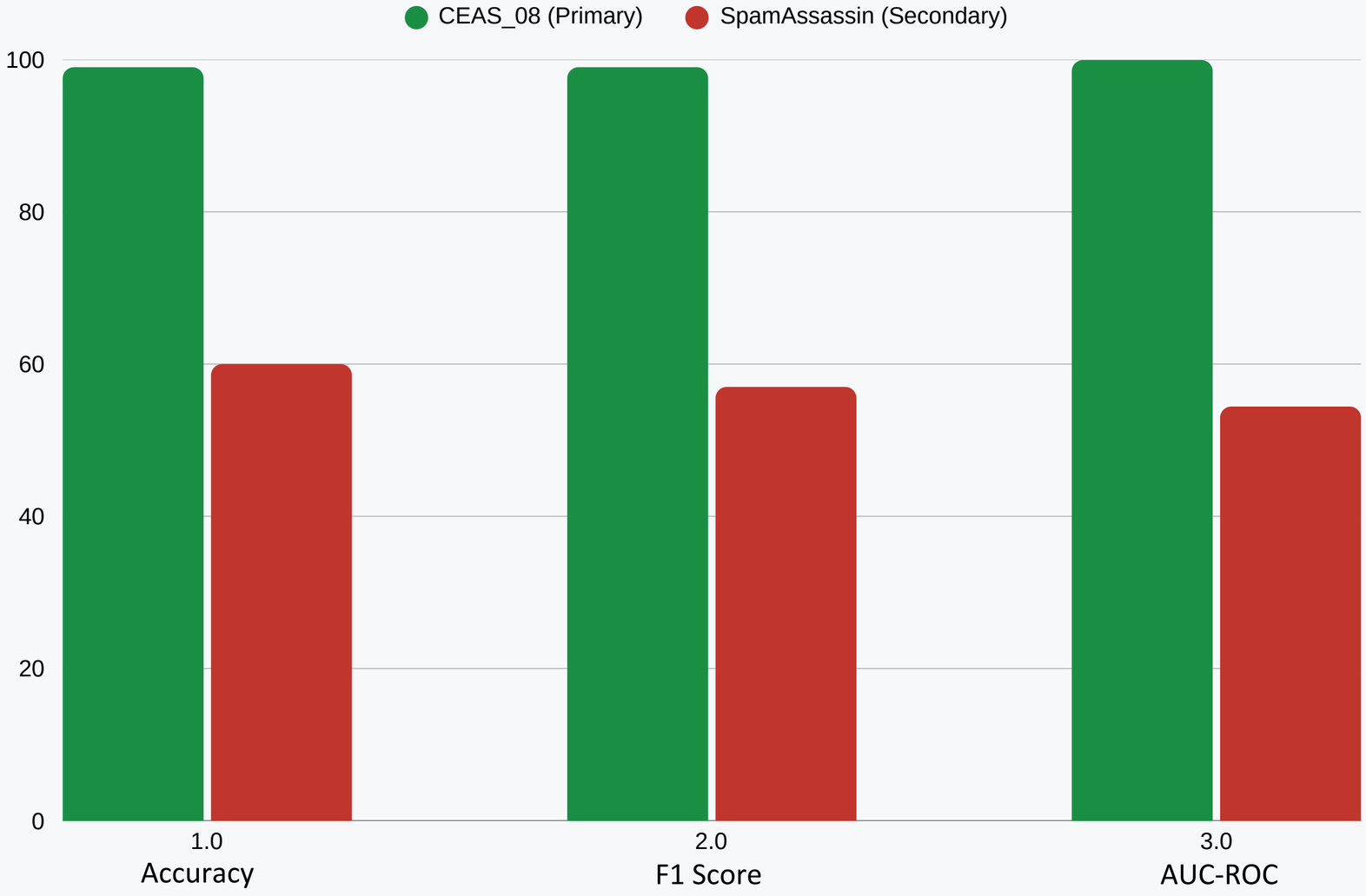
TP	4,350	FN	19
FP	105	TN	3,357

XGBoost

TP	4,345	FN	24
FP	41	TN	3,421

Tested on held-out 20% of CEAS_08 (7,831 emails). Y-axis starts at 90% to show separation.

Models Collapse by 39 Points on Unseen Data



Why the Gap Exists

Vocabulary Shift

TF-IDF learned 2008-era CEAS words. SpamAssassin uses different terminology.

Class Imbalance

CEAS: 56% phishing. SpamAssassin: 33%. Decision boundary is miscalibrated.

Feature Drift

Urgency keywords and free email signals are less predictive on SpamAssassin.

39-point accuracy drop. Near-zero phishing recall on SpamAssassin. The models learned to recognize 2008-era bait, not phishing itself.

LLMs Reason About Intent, Not Surface Patterns

How the Agent Investigates

1. `analyze_sender`

   Check domain for spoofing and brand impersonation

2. `check_urgency`

   Scan for social engineering: urgency, fear, greed

3. `extract_urls`

   Inspect URLs for raw IPs, shorteners, obfuscated links

4. `assess_context`

   Evaluate overall intent: credential requests, payment asks

Output: VERDICT + CONFIDENCE + RED FLAGS + EXECUTIVE SUMMARY

Why This Generalizes

✓ **No retraining needed**
Reasoning from pre-trained world knowledge, not dataset-specific patterns.

✓ **Understands novel attacks**
A never-seen phishing template is still recognizable by intent.

✓ **Human-readable output**
Every decision is explainable in plain English for any stakeholder.

✓ **Adaptive by design**
As attackers evolve, the agent's reasoning adapts without code changes.

ShieldAI Live Demo

Select a phishing email the ML model gets wrong and the agent gets right

Try it yourself

Scan to open
ShieldAI live

Executive Demo

1. Select sample email
2. ML scores instantly
3. LLM agent investigates
4. Compare verdicts

The Case for AI-Native Threat Detection

REDUCE BREACH COST

$4.88M

Average phishing breach cost. Early AI detection can cut this significantly. Breaches identified before 200 days cost $1.2M less than those caught late.

OPERATIONAL RESILIENCE

Zero retraining

LLM agents do not require model updates as attack patterns evolve. Your defense stays current without engineering investment.

EXPLAINABILITY

C-suite ready

Every verdict comes with a plain-English summary. Security findings become boardroom-communicable, not just analyst-readable.

Recommendation: Pilot LLM-augmented email triage on your highest-risk inboxes. Pair semantic detection with existing signature-based tools for layered defense.

Q&A

Your questions have been flagged for analysis

APPENDIX A: Citations

[1] IBM Security. Cost of a Data Breach Report 2025. Average phishing breach cost: $4.88M (up 9.7% YoY).

[2] CISA. Over 90% of cyberattacks begin with phishing as initial vector. 2025.

[3] IBM / Ponemon. Average time to detect and contain a phishing breach: 254 days. Cost of a Data Breach 2025.

[4] Hoxhunt. AI-generated phishing campaigns surged 14x in December 2025. Phishing Trends Report 2026.

[5] Keepnet Labs. AI-crafted phishing emails achieve up to 54% click rates vs 12% for traditional. 2026.

[6] Keepnet Labs. Breaches identified after 200 days cost $1.2M more than those caught earlier. 2026.

[7] Anthropic / CyberScoop. Project Glasswing announced April 7, 2026. Claude Mythos Preview identified thousands of zero-day vulnerabilities across major OSes and browsers. Partners include Amazon, Apple, Google, Microsoft, CrowdStrike.

[8] APWG. Phishing Activity Trends Report Q4 2025 (January 2026). 3.8M phishing attacks recorded globally in 2025.

[9] FBI IC3 2024 Annual Crime Report. $2.77B in BEC losses in the US in 2024. Total cybercrime losses: $16.6B.

[10] National Cybersecurity Alliance. 60% of small businesses hit by a major cyber incident close within 6 months.

APPENDIX B: Threat Model

Threat Actor	Financially motivated mass phishing operators and nation-state BEC groups with AI tooling.
Targets	Corporate email users, finance teams, executives. Financial, healthcare, and SaaS sectors most exposed.
Evasion	AI-generated content to bypass keyword filters; adversarial subject lines; novel domains not in training vocabulary.
Operational Context	Detection layer sits upstream of user inbox delivery. False negatives (missed phishing) are critical failures. False positives create alert fatigue.
ML Failure Mode	Distribution shift: model patterns are dataset-specific and brittle to vocabulary or style changes.
LLM Failure Mode	Prompt injection via email body; high latency for real-time use; cost at enterprise scale.

APPENDIX C: Technical Details

Feature Engineering (11 Handcrafted Features)

- `sender_is_free_email`
- `sender_has_numbers`
- `sender_domain_mismatch`
- `subject_has_urgency`
- `subject_has_caps`
- `subject_length`
- `body_length`
- `body_has_html`
- `body_url_count`
- `body_has_urgency`
- `has_urls`

SpamAssassin Preprocessing (Compatibility)

- Raw emails stored as single text blob with headers inline
- Regex extraction of From:, Subject:, body, and URLs
- 5,784 of 5,796 senders extracted successfully (99.8%)
- 5,790 of 5,796 subjects extracted (99.9%)
- 5,733 of 5,796 emails with body > 50 chars (98.9%)

Confusion Matrix Raw Counts (CEAS_08 test set, 7,831 emails)

Model	TP	FP	TN	FN
Random Forest	4,350	105	3,357	19
XGBoost	4,345	41	3,421	24